Electronic Store Inventory Management System

Software Requirements Specification (SRS) Table - Security Requirements

Req ID	Type	Description	Priority	Acceptance Criteria	Rationale
SEC-001	Security	The system shall require every user to log in with a unique username and password before accessing any function other than the login and password-reset pages.	High	Requests to any protected page or API without a valid session return 401 or redirect to login. No shared or anonymous accounts exist.	Related: FR-005. Establishes identity for all later checks.
SEC-002	Security	The system shall enforce a password policy of at least 8 characters with upper-case, lower-case, a digit and a special character.	Medium	A password that violates any rule is rejected with a message stating the unmet rule.	Reduces success of guessing attacks.
SEC-003	Security	Passwords shall be stored only as salted hashes using bcrypt (cost factor 10 or higher). Plaintext or reversible storage is prohibited.	High	Inspection of the users table shows only bcrypt hashes. Two users with the same password have different hashes.	Related: NFR-003. Limits damage if the database leaks.
SEC-004	Security	The system shall lock an account for 15 minutes after 5 consecutive failed login attempts.	High	The 6th attempt within the lockout window is refused even with the correct password. The lockout is recorded in the audit log.	Mitigates brute-force attacks.
SEC-005	Security	Sessions shall expire after 30 minutes of inactivity, be invalidated on logout, and use tokens that are random, HttpOnly and sent only over HTTPS.	High	A session idle for 30 minutes is rejected. A token reused after logout is rejected. Cookie flags HttpOnly and Secure are present.	Prevents session hijacking and unattended-terminal misuse at the checkout counter.
SEC-006	Security	The system shall enforce role-based access control on the server for every request. Staff may search products and process sales and returns only. Managers add purchase orders and reports. Only Admins manage users, suppliers and product deletion.	High	A Staff token calling a Manager or Admin endpoint returns 403 even when the UI hides the option. Role changes take effect on the next request.	Related: FR-005, NFR-003. UI-only hiding is not a control.
SEC-007	Security	The application database account shall hold only the privileges it needs (read and write on application tables) and shall not be able to alter schema or access other databases.	Medium	Attempting DROP or ALTER with the application credentials fails with a permission error.	Limits impact of an injection flaw or stolen application credentials.
SEC-008	Security	All communication between browser and server shall use HTTPS with TLS 1.2 or higher. Plain HTTP requests shall be redirected to HTTPS.	High	A capture of traffic shows no readable credentials. An HTTP request receives a redirect to HTTPS.	Related: NFR-011. Protects credentials and session tokens in transit.
SEC-009	Security	All user input shall be validated on the server and all database access shall use parameterized queries. Output rendered in pages shall be encoded.	High	Injection strings such as ' OR 1=1-- in login, search and product fields are rejected or stored as inert text. Script tags entered in a product name are displayed as text and do not execute.	Prevents SQL injection and cross-site scripting.
SEC-010	Security	The system shall log logins (success and failure), account lockouts, role changes, and every create, update or delete of products, stock, prices and purchase orders, recording user ID, timestamp, action and affected record.	High	Each listed action produces one log entry with all fields. Logs cannot be edited or deleted through the application and are retained for at least 6 months.	Related: FR-010, NFR-010. Gives accountability and supports dispute resolution.
SEC-011	Security	Password reset shall use a single-use token that expires in 15 minutes, delivered to the registered contact, and the response shall not reveal whether the account exists.	Medium	A used or expired token is rejected. The reset form gives the same response for known and unknown usernames.	Related: FR-012. Prevents account takeover through the recovery path.

Req ID	Type	Description	Priority	Acceptance Criteria	Rationale
SEC-012	Security	Error messages shown to users shall be generic and shall not expose stack traces, SQL text, file paths or software versions. Details shall be written to the server log only.	Medium	Forcing a database error shows a generic message to the user while the detail appears in the server log.	Related: NFR-012. Denies attackers information about internals.
SEC-013	Security	Stock changes and invoice records for a sale shall be committed in one atomic transaction, and invoices shall not be editable after creation. Corrections shall be made through a return or adjustment entry.	High	A forced failure mid-sale leaves stock and billing unchanged. No function exists to edit a finalized invoice.	Related: NFR-005. Prevents silent alteration of financial records.
SEC-014	Security	Daily database backups shall be encrypted and stored where only the Admin role and the backup service can read them. A restore test shall be performed at least once per semester.	High	A backup file cannot be read without the key. Restoring the latest backup yields a working database.	Related: NFR-009. Protects availability and confidentiality of stored data.
SEC-015	Security	The system shall not store card numbers, CVV or other payment card data. Invoices shall record only the payment method and amount.	High	Database and log inspection finds no card data. Invoice records contain payment method type only.	Removes the most damaging data from the leak surface.
SEC-016	Security	Third-party dependencies shall be listed in a software bill of materials and scanned for known vulnerabilities before each release. No known critical or high vulnerabilities shall remain unresolved at release.	Medium	The dependency scan (for example npm audit) reports zero critical or high findings at release. The bill of materials is attached to the release.	Keeps known library flaws out of the product.